

# X-39 Notaría – Runbook de la Ceremonia COLD (ejecutada, no teórica)

Anexo técnico verificable. Documenta la ceremonia real de generación de la clave soberana ML-DSA-87 (NIST FIPS-204) en hardware air-gapped y su primera co-firma en producción. Todo dato aquí citado es verificable de forma independiente, sin confiar en X-39.

Fecha de ejecución: 2026-07-16

Hardware: Raspberry Pi 500 (físico, sin SSH, sin red durante las operaciones de clave)

Software del firmante: `pi500_cold_signer.py` (este repositorio, `/app/pi500/`) — dependencia única: `pqcrypto`

Transporte: sneakernet (USB), sin ninguna conexión de red entre el firmante y el servidor

## 1. Modelo de amenaza y diseño

- La clave privada (sk) ML-DSA-87 **nace y muere en el Pi air-gapped**. Jamás toca una red.
- El servidor **solo verifica**: almacena únicamente la clave pública (pinneada vía `POST /api/notaria/admin/cold_key`, protegida por token de operador).
- La sk se guarda cifrada en reposo: AES-256-GCM con clave derivada por scrypt ( $n=2^{15}$ ,  $r=8$ ,  $p=1$ ,  $dklen=32$ ) de una passphrase que solo existe en papel.
- El material a firmar es el **payload canónico exacto** anclado en Bitcoin vía OpenTimestamps (`GET /api/notaria/proof/<aid>.json` = pre-imagen del `proof_hash`).
- Verificación humana obligatoria en el Pi: el operador compara el SHA-256 del payload contra el certificado antes de teclear `FIRMAR`.

## 2. Ceremonia ejecutada – registro real

### 2.1 Generación (con rotación honesta)

- **Keygen #1** (fingerprint `3a026e152eee14284480e992879a736fc634045733ed32845d04851eae05c4b9`): ROTADA el mismo día. Causa: passphrase irre recuperable (el prompt de keygen la pide una sola vez, sin confirmación; error humano de tecleo). Al estar cifrada con AES-GCM, la sk es irre recuperable por diseño — no existe puerta trasera. Coste de la rotación: cero (la clave no había firmado nada). La sk fue borrada del Pi.
- **Keygen #2 (DEFINITIVA)**:
- `fingerprint = 8453a25a41d6fe8fcb5647600f042a7c303daaca79b80928534025711981c6a1` (= SHA-256 de la clave pública de 2592 bytes)
- Passphrase verificada visualmente antes del keygen (editor local, sin guardar) y anotada exclusivamente en papel.

### 2.2 Registro de la pubkey (sneakernet, viaje 1)

- `mldsa87.pk` (pública, 3456 chars base64 = 2592 bytes) viajó por USB al equipo online.
- Registro: `POST /api/notaria/admin/cold_key` con `X-Admin-Token`.

- El servidor recalculó el fingerprint de forma independiente: **coincidencia bit a bit** con el mostrado por el Pi. `registered_at = 2026-07-16T09:58:44Z`.
- Verificación pública en cualquier momento: `GET /api/notaria/cold_key`.

## 2.3 Co-firma soberana (sneakernet, viaje 2)

- Acuerdo objetivo: `85f43a8b9cc748abe30a` (sellado, anclado en Bitcoin).
- Payload: `GET /api/notaria/proof/85f43a8b9cc748abe30a.json` — 445 bytes, `sha256 = f16996256429f6f3548e6e23863951416725017fa8625a0f4232f08d1abad1a7`.
- En el Pi (sin red): el script mostró el mismo sha256 → el operador confirmó → **FIRMAR**.
- Firma ML-DSA-87 emitida: 4627 bytes, `sha256(sig) = 76dfb93ac5d05edac85b2c1f9633d8f8eab5dd1873555a2979e6d01465b21b43`.
- Candado local: el propio Pi re-verificó la firma offline contra la pubkey antes de emitirla.
- Subida: `POST /api/notaria/agreements/85f43a8b9cc748abe30a/cold_signature` → el servidor verificó la firma contra la pubkey pinneada → `ok: true`, `verified_at = 2026-07-16T09:58:44Z`.

## 2.4 Estado final del acuerdo (público)

```
GET /api/notaria/public/85f43a8b9cc748abe30a
ots_status = anchored_btc (bloque Bitcoin #957242)
cold.tier = COLD · ML-DSA-87
cold.fingerprint = 8453a25a41d6fe8fcb5647600f042a7c303daaca79b80928534025711981c6a1
```

Doble garantía independiente:

1. **Existencia y fecha**: OpenTimestamps → cadena de bloques de Bitcoin (bloque 957242).
2. **Autoría post-cuántica**: firma ML-DSA-87 producida en hardware air-gapped cuya sk jamás ha estado en una máquina conectada.

## 3. Verificación independiente (sin confiar en X-39)

Descarga el bundle autocontenido: `GET /api/notaria/proof/85f43a8b9cc748abe30a.zip`  
(ZIP determinista: mismo acuerdo → mismos bytes). Contiene `proof.json`, `proof.json.ots`, `signatures.json` y `README.md` con los 4 pasos:

```
# 1. Integridad
sha256sum proof.json          # = proof_hash

# 2. Fecha anclada en Bitcoin (100% trustless con nodo local)
ots verify proof.json.ots

# 3. Firma post-cuántica (pk y sig embebidas; no requiere servidor)
pip install pqcrypto 88 python3 verify_mldsa.py

# 4. Vínculo con el documento original
# sha256 del documento (que solo poseen las partes) == content_hash de proof.json
```

## 4. SEC-003 – retirada de la clave WARM (mismo día)

Tras demostrar el ciclo COLD completo, la clave WARM de operador (ML-DSA-87 cuya sk vivía en el servidor) fue **retirada**: la sk se eliminó de la base de datos y el sellado ya no produce firmas de servidor. Las firmas WARM históricas siguen siendo verificables porque cada acuerdo lleva la clave pública embebida. Desde esta fecha, la única autoridad de firma post-cuántica del sistema es la clave COLD air-gapped.

Racional: una firma emitida por un servidor conectado solo prueba que "el servidor firmó". Una firma emitida por hardware air-gapped con verificación humana del hash prueba autoría

soberana. X-39 no pide confianza: publica la clave, el payload y la firma, y desaparece de la ecuación.

## 5. Lecciones operativas registradas

- El keygen debería pedir la passphrase dos veces (confirmación) — la rotación de la clave #1 lo demostró. Mitigado operativamente: verificación visual previa de la passphrase.
- `hashlib.scrypt` en Raspberry Pi OS requiere `maxmem=134217728` explícito (límite OpenSSL).
- Sneakernet real: usar globs (`x39-prueba*.json`) y renombrar a nombres cortos evita errores de transcripción con nombres largos y paréntesis de los navegadores.
- El USB VAULT (respaldo de claves) jamás se conecta a máquinas online; el transporte se hace con un USB desechable — la pk y la firma son públicas, solo importa la integridad, garantizada por comparación de hashes en ambos extremos.